# Cybersecurity Capstone Project

*Full Security Assessment Report — OWASP Juice Shop Lab*

Prepared by: Lochna Sabnis

Skill Set Go EduTech — Cybersecurity Internship, Week 4 Capstone

October 2026

# 1. Executive Summary

This report presents the complete findings of a 4-week structured security assessment conducted against OWASP Juice Shop, an intentionally vulnerable web application used as a legal practice environment within a local, isolated lab (VirtualBox + Kali Linux + Docker). The assessment progressed from foundational reconnaissance through active exploitation, log-based threat detection, and a formal risk and incident-response analysis.

Eight distinct security findings were identified, ranging from Critical to Low severity, including a critical authentication bypass via SQL injection, a working cross-site scripting (XSS) exploit, insecure session cookie configuration, and an exposed directory containing sensitive-looking files. A risk register and incident-response procedure were developed based on these findings, and this report consolidates all supporting evidence gathered throughout the engagement.

The overall security posture of the target reflects common real-world web application weaknesses: missing defense-in-depth controls (such as a Content-Security-Policy), permissive configurations (wildcard CORS), and insufficient protection of session tokens. The highest-priority recommendation arising from this assessment is the enforcement of parameterized database queries, strict input sanitization, and multi-factor authentication on all privileged accounts.

# 2. Scope and Rules of Engagement

**In scope:**

- OWASP Juice Shop web application and REST API at http://localhost:3000
- Host ports exposed by the Docker container running the target

**Out of scope:**

- Any system other than the local lab environment
- Denial-of-service testing and destructive actions against the host or VM

Authorization: Self-owned practice environment; no third-party systems were tested. Methodology combined PTES-style phases with reference to the OWASP Web Security Testing Guide (WSTG) and OWASP Top 10 (2021).

# 3. Methodology

- Reconnaissance — identify the technology stack, open ports, and HTTP behavior (nmap, curl, whatweb)
- Enumeration — discover hidden directories and endpoints (gobuster, robots.txt review)
- Manual Exploitation — confirm and exploit vulnerabilities by hand (SQL injection, XSS, session analysis)
- Log-Based Threat Detection — analyze authentication logs for brute-force indicators of compromise
- Risk Assessment — rate each finding by likelihood and impact, and define controls
- Incident Response Planning — define a formal response procedure for a simulated attack scenario

# 4. Findings Summary

The following eight findings were identified during the structured assessment (Task 4.1), each mapped to its corresponding OWASP Top 10 (2021) category:

| ID | Vulnerability | OWASP Category | Severity |
|---|---|---|---|
| F-01 | SQL Injection (login bypass) | A03 Injection | Critical |
| F-02 | Cross-Site Scripting (XSS) | A03 Injection | High |
| F-03 | Insecure session/token handling | A07 Auth Failures | High |
| F-04 | Exposed directory (/ftp) with sensitive files | A05 Security Misconfig. | High |
| F-05 | Missing Content-Security-Policy header | A05 Security Misconfig. | Medium |
| F-06 | Wildcard CORS policy | A05 Security Misconfig. | Medium |

| ID | Vulnerability | OWASP Category | Severity |
|---|---|---|---|
| F-07 | Information disclosure via robots.txt | A05 Security Misconfig. | Low |
| F-08 | Unexpected open port (34979) | A05 Security Misconfig. | Low |

Detailed evidence and step-by-step reproduction for each finding is provided in the supporting Task 4.1 Structured Security Assessment spreadsheet submitted alongside this report.

## 4.1 Key Finding Detail — SQL Injection (F-01, Critical)

The login form's email field accepted the payload ' OR 1=1-- with any password value. This manipulated the backend SQL query to always evaluate as true, bypassing authentication entirely without valid credentials and granting administrator-level access.

## 4.2 Key Finding Detail — Exposed Sensitive Directory (F-04, High)

Directory brute-forcing (gobuster) combined with a robots.txt review revealed a publicly browsable /ftp directory. This directory exposed files appearing to contain credentials (incident-support.kdbx), legal and acquisition documents, and backup files (.bak) — a significant information disclosure risk if this pattern existed in a production system.

# 5. Risk Register

Each finding was assessed for likelihood and impact to determine an overall risk rating, with a recommended control defined for each (full detail in Task 4.2 Risk Register spreadsheet):

| Risk ID | Risk | Rating | Recommended Control |
|---|---|---|---|
| R-01 | SQL Injection | Critical | Parameterized queries / prepared statements |
| R-02 | XSS (search field) | High | Input sanitization + strict CSP |
| R-03 | Insecure session cookie | High | Set HttpOnly, Secure, SameSite flags |
| R-04 | Exposed /ftp directory | High | Disable directory listing; restrict access |
| R-05 | Missing CSP header | Medium | Implement Content-Security-Policy |
| R-06 | Wildcard CORS | Medium | Restrict to trusted origin allow-list |
| R-07 | robots.txt disclosure | Low | Avoid listing sensitive paths |
| R-08 | Unexpected open port | Low | Disable unused service / firewall rule |

# 6. Incident-Response Procedure Summary

A simulated attack scenario was analyzed (Task 3.3 / 4.3): a brute-force SSH login attack succeeded on the "admin" account, followed by reconnaissance, a privilege escalation attempt against /etc/shadow, and download/execution of an external payload script. The full incident-response procedure (Task 4.3) defines actions across six phases:

- Preparation — centralized log monitoring and defined alert thresholds
- Identification — detecting repeated failures followed by a successful login as a compromise indicator
- Containment — disabling the compromised account and blocking the source IP
- Eradication — removing the malicious payload and auditing for backdoors
- Recovery — restoring the account only after password reset and verification
- Lessons Learned — root cause identified as weak password policy; MFA recommended

## 7. Overall Recommendations

- Implement parameterized queries across all database-facing input fields
- Deploy a strict Content-Security-Policy to limit the impact of any successful script injection
- Correct session cookie configuration (HttpOnly, Secure, SameSite)
- Remove or properly restrict the exposed /ftp directory and any similar publicly accessible paths
- Enforce multi-factor authentication (MFA) on all administrative accounts — identified as the single highest-impact control against the simulated attack scenario
- Adopt continuous log monitoring with automated alerting at defined severity thresholds, rather than manual review alone

## 8. Conclusion

This capstone project consolidated four weeks of hands-on cybersecurity practice — from networking and Linux fundamentals, through ethical hacking and web application exploitation, to SOC-style log analysis and a formal risk-based security assessment. The findings and controls documented here reflect patterns commonly seen in real-world security incidents, reinforcing that foundational practices — input validation, secure session handling, least-privilege access, and layered defenses — remain the most effective defenses against the majority of attacks observed in this assessment.

## 9. Supporting Evidence

The following supporting files accompany this report and are available in the project's GitHub repository (Week1 through Week4 folders):

- Task_4.1_Structured_Security_Assessment.xlsx — full assessment log and findings detail
- Task_4.2_Risk_Register.xlsx — complete risk register with likelihood/impact matrix
- Task_4.3_Incident_Response_Procedure.docx — full incident-response procedure
- Week 1-3 folders — networking notes, Linux hardening exercises, OWASP Top 10 study, vulnerability findings, log analysis, and monitoring dashboard